Microsoft Azure FERPA Compliance Framework Mapping

Source Resource: Microsoft Compliance Framework Mapping Workbook & Offering

Original URL: https://aka.ms/AzureFERPAMapping (and Microsoft Service Trust Portal)

Regulatory Standard: 34 CFR Part 99 (Family Educational Rights and Privacy Act)

Mapped Frameworks: ISO/IEC 27001:2013/2022, ISO/IEC 27018:2019, NIST SP 800-53 Rev. 4/5, NIST SP 800-30

1. Overview of the Compliance Framework Mapping

The **Azure FERPA Compliance Framework Mapping** is an authoritative reference workbook developed by Microsoft compliance architects and distributed via the Service Trust Portal. It defines compliance domains, control objectives, and technical implementations mapping statutory FERPA clauses (34 CFR Part 99) directly to cloud architectural controls, international security standards (ISO 27001/27018), and federal cybersecurity guidelines (NIST SP 800-53). For software engineers and test teams, this mapping translates legal privacy mandates into concrete, auditable software controls.

2. Comprehensive FERPA Control to Security Architecture Mapping

---

FERPA Citation & Requirement	Regulatory Intent & Obligation	ISO 27001 / ISO 27018 & NIST 800-53 Alignment	Technical Software & Cloud Architectural Controls
34 CFR § 99.30 Prior Written Consent Requirement	Educational agencies/institutions must obtain signed, dated written consent before disclosing personally identifiable information (PII) from education records, specifying records disclosed, purpose, and recipient parties.	• ISO 27018: A.3.1 (Consent & Choice) • NIST 800-53: AC-3 (Access Enforcement), PT-2 (Authority to Collect)	• Digital consent capture module with timestamp, electronic signature, and scope verification. • Automated policy gate preventing data export or third-party API transmission unless active consent flag exists or statutory exception applies.
34 CFR § 99.31(a)(1) & § 99.33(a) School Official Exception & Re-disclosure Ban	Allows disclosure to outsourced contractors/ISVs without prior consent if: (1) performs institutional service; (2) legitimate educational	• ISO 27001: A.15 (Supplier Relationships) • ISO 27018: A.2.1 (Customer Data Processing), A.6.1 (Commercial Use Restrictions) • NIST 800-53: SA-9 (External System	• Multi-tenant logical data isolation (partition keys, separate schemas/containers per district). • Complete prohibition of secondary telemetry mining, ad-tracking pixels, or cross-district data aggregation.

FERPA Citation & Requirement	Regulatory Intent & Obligation	ISO 27001 / ISO 27018 & NIST 800-53 Alignment	Technical Software & Cloud Architectural Controls
	interest; (3) under direct school control; (4) complies with re-disclosure restrictions (cannot use data for secondary commercial/advertising purposes).	Services), AC-21	• Granular API token scoping limited to institutional tenancy. • Data processing addendum (DPA) enforcement in software configuration.
34 CFR § 99.10 Right to Inspect & Review Education Records	Parents and eligible students have the legal right to inspect and review student education records within 45 calendar days of request submission.	• ISO 27018: A.10.1 (Data Subject Access) • NIST 800-53: AC-3, PT-3 (Privacy Notice and Consent)	• Automated Data Subject Access Request (DSAR) intake and fulfillment engine. • Cross-system query federation returning all records associated with a student ID across core SIS, LMS, and messaging systems. • Automated countdown SLA timer with alerts at Day 15, Day 30, and Day 40. • Secure, encrypted export format (PDF/JSON) with

FERPA Citation & Requirement	Regulatory Intent & Obligation	ISO 27001 / ISO 27018 & NIST 800-53 Alignment	Technical Software & Cloud Architectural Controls
			redaction capabilities for other students' PII.
34 CFR § 99.20 – 99.22 Right to Seek Amendment & Contested Information	Allows parents/students to contest inaccurate or misleading data. If the school refuses amendment, must support formal hearing and allow contested statements to accompany contested records permanently.	• ISO 27001: A.12.1 (Operational Procedures) • ISO 27018: A.10.2 (Correction and Erasure) • NIST 800-53: SI-10 (Information Input Validation), AU-3	• Software workflow for submitting amendment requests and tracking adjudication status. • Database schema support for attaching persistent explanatory notes/statements to disputed records. • Automated bundling of the contested statement whenever the disputed record is queried, viewed, or exported.
34 CFR § 99.32 Recordkeeping & Access Audit Logging	Mandatory maintenance of an audit record for each request and disclosure of PII from education records. Audit record must be	• ISO 27001: A.12.4 (Logging and Monitoring) • ISO 27018: A.11.1 (Audit Logging) • NIST 800-53: AU-2 (Audit Events),	• Append-only, immutable audit trail for all read, write, export, update, and delete actions on education records. • Logged fields: Timestamp (UTC), User ID, Role, Student ID, Record Type, Operation,

FERPA Citation & Requirement	Regulatory Intent & Obligation	ISO 27001 / ISO 27018 & NIST 800-53 Alignment	Technical Software & Cloud Architectural Controls
	retained as long as student records are kept and be inspectable by parents.	AU-3 (Audit Content), AU-6, AU-9 (Protection of Audit Info)	Client IP, Authorization Reason / Legitimate Interest. ● Tamper-proofing via digital signatures or immutable cloud storage (WORM storage). ● Parent access view displaying legitimate inspection logs.
34 CFR § 99.37 Directory Information & Opt-Out Safeguards	School may designate directory information (name, address, dates of attendance) for public release, but must notify parents annually and respect opt-out / FERPA privacy blocks.	● ISO 27018: A.3.2 (Withdrawal of Consent) ● NIST 800-53: AC-3, PT-4 (Consent and Choice)	● Database privacy flag (e.g., ferpa_directory_opt_out = true) at the student record level. ● Automated query filtering: public queries, honors rolls, yearbooks, or external rosters strictly suppress opted-out students. ● Real-time synchronization of opt-out status across all consuming application modules.
34 CFR § 99.31(a)(10) &	Permits disclosure of PII to	● ISO 27001: A.16 (Incident	● Emergency "Break-Glass" access procedure with

FERPA Citation & Requirement	Regulatory Intent & Obligation	ISO 27001 / ISO 27018 & NIST 800-53 Alignment	Technical Software & Cloud Architectural Controls
§ 99.36 Health and Safety Emergencies	appropriate officials without consent if knowledge of information is strictly necessary to protect the health or safety of the student or other individuals.	Management) ● NIST 800-53: CP-2 (Contingency Plan), IR-4	elevated privilege bypass. ● Mandatory prompt requiring user to document the articulable and significant health/safety threat. ● Automated real-time security alerting sent to CISO and Privacy Officer upon break-glass activation.
FERPA Reasonable Methods Standard (34 CFR § 99.31(a)(1)(ii)) Physical, Administrative & Technical Safeguards	Institutions must use reasonable methods to ensure school officials obtain access to only those education records in which they have legitimate educational interests.	● ISO 27001: A.9 (Access Control), A.10 (Cryptography), A.13 (Communications Security) ● NIST 800-53: AC-2, AC-6 (Least Privilege), SC-8, SC-13, SC-28	● Role-Based and Attribute-Based Access Control (RBAC/ABAC). ● Data-at-rest encryption using AES-256 with managed KMS. ● Data-in-transit encryption enforcing TLS 1.2 or TLS 1.3 with Perfect Forward Secrecy. ● Session timeout enforcement (e.g., 15 minutes of inactivity). ● Strict input sanitization, automated static/dynamic

FERPA Citation & Requirement	Regulatory Intent & Obligation	ISO 27001 / ISO 27018 & NIST 800-53 Alignment	Technical Software & Cloud Architectural Controls
			vulnerability testing (SAST/DAST).